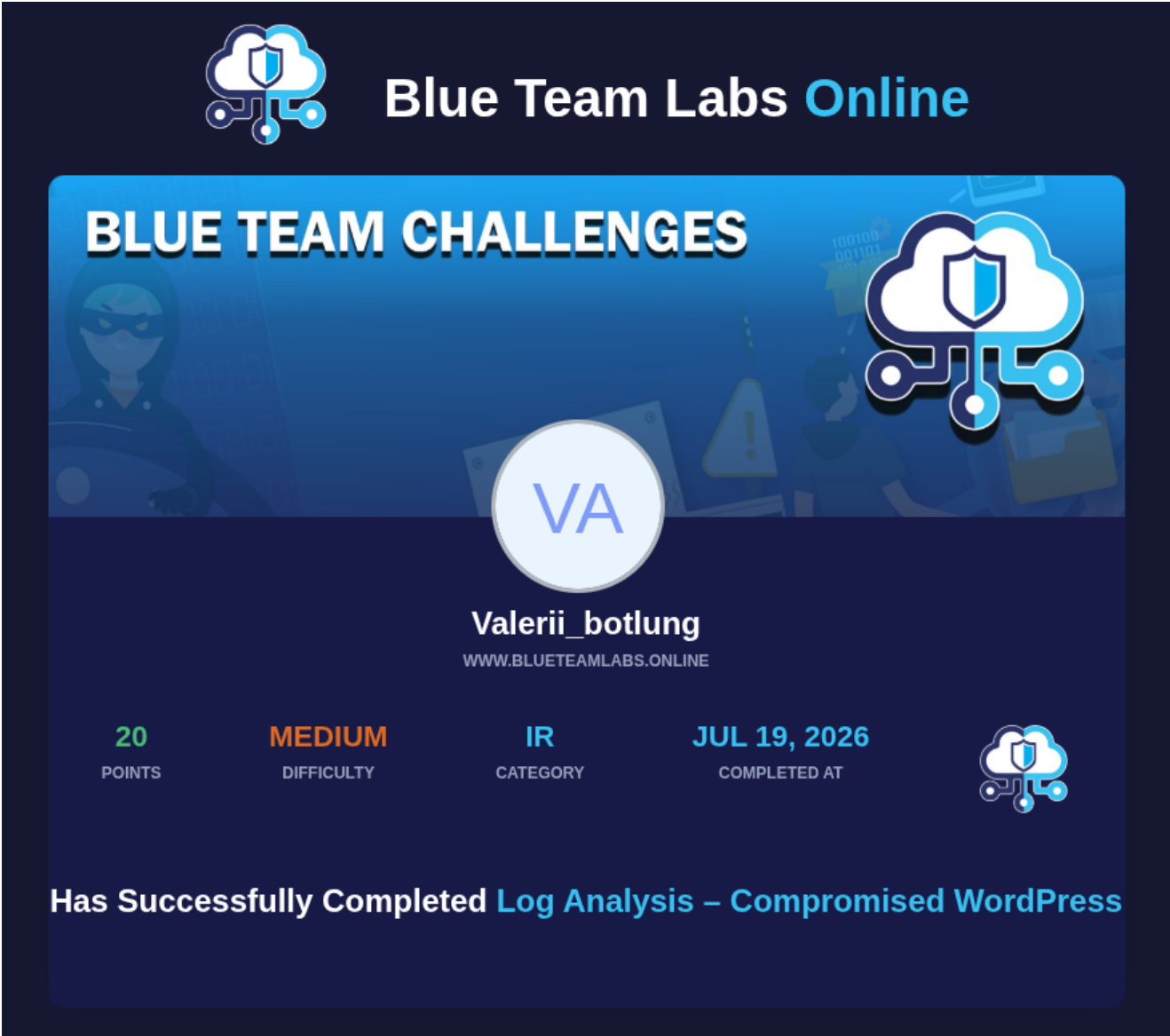


BTLO Challenge: Compromised WordPress

Расследование инцидента безопасности на основе анализа веб-логов (Log Forensics)



The image is a challenge completion card from Blue Team Labs Online. At the top left is the logo, a blue cloud with a shield and circuit lines. To its right is the text 'Blue Team Labs Online'. Below this is a blue banner with 'BLUE TEAM CHALLENGES' in white. In the center is a white circle with 'VA' in blue. Below the circle is the name 'Valerii_botlung' and the URL 'WWW.BLUETEAMLABS.ONLINE'. At the bottom, there are five items: '20 POINTS' (green), 'MEDIUM DIFFICULTY' (orange), 'IR CATEGORY' (blue), 'JUL 19, 2026 COMPLETED AT' (blue), and a small logo. At the very bottom, it says 'Has Successfully Completed Log Analysis – Compromised WordPress'.

Blue Team Labs Online

BLUE TEAM CHALLENGES

VA

Valerii_botlung
WWW.BLUETEAMLABS.ONLINE

20
POINTS

MEDIUM
DIFFICULTY

IR
CATEGORY

JUL 19, 2026
COMPLETED AT

Has Successfully Completed Log Analysis – Compromised WordPress

Кликните на изображение выше, чтобы перейти к подтверждению выполнения лабораторной работы.

Описание инцидента

Один из сайтов на платформе WordPress был скомпрометирован неизвестным способом. Основная гипотеза предполагала наличие уязвимости удаленного выполнения кода (RCE) в одном из установленных плагинов, что позволило злоумышленнику получить доступ к операционной системе сервера. В ходе анализа файла `access.log` хронология атаки была полностью восстановлена.

Сводная таблица результатов расследования

Выявленный артефакт / Вопрос	Значение / Ответ
Кастомная панель администратора (с токеном)	/wp-login.php?itsec-hb-token=adminlogin
Инструменты автоматизации атакующего	WPScan, sqlmap
CVE уязвимости в 'Contact Form 7'	CVE-2020-35489
Скомпрометированный плагин (вектор входа)	Simple File List
Имя загруженного PHP веб-шелла	fr34k.php
Финальный HTTP-код ответа веб-шелла	404

Ключевые этапы анализа логов

1. Поиск панели входа и инструментов

С помощью фильтрации уникальных URI был обнаружен скрытый адрес панели администратора, настроенный через плагин безопасности iThemes Security. Анализ полей User-Agent выявил активность автоматизированных сканеров:

```
WPScan v3.8.10 (https://wpscan.org/)  
sqlmap/1.4.11#stable (http://sqlmap.org)
```

2. Анализ вектора атаки и загрузки шелла

Запросы к плагину contact-form-7 версии 5.3.1 указали на попытку эксплуатации старой RCE-уязвимости (CVE-2020-35489). Однако успешное закрепление произошло через другой плагин — Simple File List, куда в директорию uploads был загружен вредоносный скрипт.

Запросы к веб-шеллу фиксировались по следующему пути:

```
/wp-content/uploads/simple-file-list/fr34k.php
```

Примечание по закрытию инцидента: Последний зафиксированный запрос к файлу шелла вернул статус 404, что подтверждает факт его последующего удаления из файловой системы сервера.